The Jevil Is in the Details: State Recovery and Fresh-Message Forgery Below Jevil's Signature Cliff

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

15 October 2026

AI disclosure and review status. This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex performed AI-assisted target discovery, attack-history searching, scheme and source review, cryptanalysis, implementation, experimentation, and technical writing. Specialist AI agents worked on bounded components of the analysis and implementation. A separately tasked hostile AI reviewer replayed and challenged the primary result, and a fresh-context AI agent independently implemented and reproduced the attack on a new key. These were AI review and AI reproduction, not human verification. The primary experiment, hostile adversarial review, fresh-context independent reproduction, final exact-target attack-history review, and independent Publication Review passed. No independent human verification was performed; it is optional for this audit. OpenAI Codex generated and selected the title and intentionally chose "The Jevil Is in the Details" as scheme-related wordplay on "the devil is in the details," because the flaw lies in Jevil's width-four opening and encoding details.

Abstract

Jevil is a post-quantum few-time signature scheme designed to remain secure for $n^\star = 1023$ ordinary signatures and to reveal its signing polynomial at the advertised 1,024th-signature cliff. We give a different, practical attack below that cliff against the current fourth-revision, source-backed profile. Each ordinary zk-WHIR proof authenticates 64 positions of a reused initial commitment, and each position discloses a width-four Reed–Solomon leaf. At this profile the committed object has four rows of degree below 32,768. Consequently, 32,768 distinct leaf positions determine every row, including the polynomial coefficients and commitment randomness needed to rebuild an equivalent signing state.

Our primary public-data process used 641 ordinary signing queries, authenticated 41,024 openings at 35,203 distinct positions, recovered all four rows, rebuilt the exact public root and evaluation, and produced a signature on an unqueried message. The unmodified ordinary verifier accepted it. A hostile reviewer replayed all public inputs and produced a second accepted signature. A fresh-context implementation independently repeated the full attack on a new key with 650 queries and 35,603 distinct positions; a second untouched-source verifier accepted the forgery. Changed-message, changed-root, corrupted-row, and altered-signature controls rejected.

The executable claim is pinned to the source commit identified in Section 2. The same full-recovery threshold also follows analytically for the intended four-row encoding of zk-WHIR Definition 3.22. We keep that analytic scope distinct from the source's nonconforming contiguous row allocation. We make no claim that Reed–Solomon interpolation is new, no minimum-query claim, and no broad priority claim about all Jevil development versions.

1 Introduction

Jevil is a transparent post-quantum few-time signature whose defining feature is a sharp, count-triggered failure point [1]. For the largest source-backed row, a signer may issue at most $n^\star = 1023$ signatures. Each signature publishes $K = 16$ message-derived evaluations of a secret polynomial of dimension $M = (n^\star + 1)K = 16{,}384$. The paper deliberately chooses this dimension so that signature 1,024 can

provide enough evaluations to recover the polynomial. Below that boundary, the paper claims more than 124 bits of classical EUF-CMA-$n^\star$ security.

The deliberate cliff counts the 16 explicit message-derived evaluations. The zk-WHIR proof attached to every signature exposes a second and larger stream of reused-commitment data: 64 authenticated initial-codeword leaves. Each leaf contains four field elements. At the audited endpoint those elements are one evaluation from each of four degree-below-32,768 Reed–Solomon rows. Accumulating 32,768 distinct outer positions therefore recovers the complete committed state. The opening interface accepts fresh prover randomness separately from that state, so the recovered state is an equivalent signing witness.

The attack has five concrete steps:

1. request ordinary signatures on distinct messages;
2. verify them and extract only their authenticated initial width-four openings;
3. deduplicate positions and interpolate the four rows after 32,768 distinct positions have appeared;
4. re-encode the recovered rows, require the exact public root and public polynomial evaluation, and reconstruct signer state; and
5. use fresh opening randomness to sign an unqueried message and submit the result to the unchanged ordinary verifier.

This is ordinary erasure recovery for Reed–Solomon codes, followed by state reconstruction. Reed–Solomon interpolation and fast multipoint algorithms are standard [3, 4]; we make no methodological-novelty claim. The result is the application of that standard machinery to Jevil's accumulated width-four openings, with a full-parameter public-data implementation and an ordinary-verifier-accepted fresh-message forgery.

Contributions and scope. We identify the unit mismatch between the claimed hiding budget and the width-four leaves; prove full recovery under the paper's intended Definition 3.22 encoding and the pinned source encoding; implement the attack at $n^\star = 1023$ without using signature 1,024; and report a primary run, hostile replay, and independently written fresh-key reproduction. The executable result applies to one precisely pinned source-backed profile. The paper/source correspondence and encoding distinctions in Sections 2 and 4 are part of the claim.

2 Exact target and claim boundary

2.1 Paper and source pin

The paper target is Nadim Kobeissi's *Jevil: A Catastrophic-Failure-by-Design Signature Scheme*, IACR ePrint 2026/1103, current revision 4 [1]. The pinned 404,750-byte PDF has SHA-256 digest

`c0da79bdf8b2d2c9667d6167d6ab008b8eeaf838b463a40eb64f2abe123c01c5`.

Only revision 4 of the four reported revisions was available for bytewise inspection.

The executable target is the author's `symbolicsoft/jevil` repository at commit

`905466fbe3be99d90fd41e461e0c68271d09104b`

and Git tree

`f4a7366dac1a1f079186d87a2aca79c9918ee79e`.

The source archive has SHA-256 `b8817b85a5f90dd4045c8e635dad806e3973b26dbb36c01d7d2a37fcdff0270e`. The commit predates the final PDF by about 19 hours 47 minutes, and the final paper does not name a source commit. We therefore call this the *source-backed current-revision profile*, rather than asserting byte-exact source conformance to every sentence of the PDF.

2.2 Frozen parameter row

Table 1 records the values material to the attack. The working field is a degree-four extension of the Goldilocks prime field. The source-backed Poseidon2 capacity is $c = 4$. The paper discusses $c = 6$ as a possible higher quantum-collision-security choice, but that row is not the executed target.

Quantity	Frozen value
Ordinary signing budget $n^\star$	1,023
Advertised cliff signature $n^\star + 1$	1,024
Message-derived evaluations per signature K	16
Secret polynomial dimension M / degree bound	16,384 / $< 16{,}384$
HVZK padding B	114,688
Initial encoded message length $N = M + B$	131,072
Main-code rate / width	1/4 / 4
Row count / row dimension	4 / 32,768
Initial outer domain	131,072 width-four leaves
Initial openings per signature θ	64
Poseidon2 capacity	4
Public key / reported signature size	68 bytes / about 337 KB

Table 1: The exact $n^\star = 1023$ source-backed profile.

The paper claims EUF-CMA-$n^\star$ security above 124 classical bits for at most 2^{128} random-oracle queries. At capacity four, its own analysis places the quantum collision floor at about 85 bits; that separate generic floor is not used in our attack.

2.3 Dated attack-history statement

No prior public practical signing attack against the current fourth-revision Jevil profile at $n^\star = 1023$, $c = 4$, using at most 1,023 ordinary signing queries was located in the searches performed through 15 October 2026. This is a bounded, dated search result. It is not a claim that no Jevil development version was ever attacked. Section 9 discloses a pre-publication root-binding forgery fix and a later Merkle-helper report.

3 Jevil and its two disclosure streams

3.1 Signing polynomial and advertised cliff

Let

$$f(X) = \sum_{j=0}^{M-1} c_j X^j \in \mathbb{F}[X], \qquad c = (c_0, \ldots, c_{M-1}) \in \mathbb{F}^M.$$

Key generation derives c from a 32-byte seed. It commits once to c using zk-WHIR, deriving commitment padding $r_{\mathrm{zk}} \in \mathbb{F}^B$, and publishes

$$\mathsf{pk} = (\mathsf{root}, w, n^\star), \qquad w = f(z),$$

where z is derived from the root. The commitment state is cached and reused for every signature under the key.

For a message m, the signer derives $K = 16$ positions and corresponding field points $x_1, \ldots, x_K$, publishes $y_t = f(x_t)$, and batches those evaluations with (z, w) into one linear-form claim. In simplified notation, Fiat–Shamir challenges $\beta_1, \ldots, \beta_{K+1}$ define

$$\alpha = \sum_{t=1}^{K} \beta_t (1, x_t, \ldots, x_t^{M-1}) + \beta_{K+1}(1, z, \ldots, z^{M-1}),$$

$$v = \sum_{t=1}^{K} \beta_t y_t + \beta_{K+1} w.$$

The proof $\pi \leftarrow \mathsf{Open}(\mathsf{st}, \alpha, v; \rho)$ uses a fresh 32-byte prover-randomness seed ρ. The signature is $((y_1, \ldots, y_K), \pi)$, and ordinary verification re-derives the positions and checks the proof against root.

Jevil chooses $M = (n^\star + 1)K$. Its advertised cliff is based on accumulating the explicit (x_t, y_t) pairs: signature 1,024 supplies the next bucket of 16 evaluations from which the degree-below-16,384 polynomial can be interpolated. That 1,024th signature is outside the permitted budget and outside our attack.

3.2 The initial-codeword openings

The proof itself publishes another stream. In its first round, the verifier derives 64 in-domain positions and authenticates the corresponding initial commitment leaves by Merkle multiproof. Jevil sets the interleaving width to four, so each authenticated outer leaf exposes four field elements. The same initial root is reused across all ordinary signatures.

The paper's multi-opening argument charges $\theta = 64$ positions per signature against $B = N - M =$ 114,688 scalar hiding slots. This mixes units. A width-four outer position supplies four scalar values; in the cited four-row construction, one position supplies one value from each row, each of which has only $B/4$ random coefficients. The relevant outer-position hiding allowance is therefore $B/4 = 28{,}672$, while the paper permits $n^\star\theta = 65{,}472$ outer draws.

This accounting defect has a direct recovery consequence. Each row has dimension $N/4 = 32{,}768$. Once the accumulated signatures authenticate that many distinct outer positions, the entire committed state is public.

4 Encoding interpretations and full-state recovery

The paper and source do not allocate the encoded state identically. Keeping the three coherent readings separate prevents a source-layout defect from being mistaken for the design-level cause of full recovery.

Reading	Encoded object	One outer leaf	Full-recovery threshold
Literal paper wording	One scalar $\mathsf{RS}[4N, N]$ codeword packed into disjoint width-four stripes	Four scalar evaluations	32,768 stripes provide N evaluations
Definition 3.22	Four $\mathsf{RS}[N, N/4]$ rows after separately splitting c and r_{zk}	One evaluation from each row	32,768 positions interpolate every row
Pinned source	Concatenate $c \,\|\, r_{\mathrm{zk}}$, split it into four contiguous chunks, and encode each as an $\mathsf{RS}[N, N/4]$ row	One evaluation from each row	32,768 positions interpolate every row

Table 2: Three encoding readings. They differ in coefficient allocation but share the same full-recovery threshold. The literal paper stripe map is not fully pinned.

In the intended Definition 3.22 allocation [2], each row contains 4,096 coefficients from c and 28,672 coefficients from r_{zk}. In the pinned source, row zero contains all 16,384 coefficients of c followed by 16,384 padding coefficients, while rows one through three contain only padding. This source layout changes the earliest partial-leakage threshold. It does not change the degree bound or the 32,768-position threshold for complete recovery.

Lemma 1 (Width-four interpolation)**.** *Let $p_0, \ldots, p_3 \in \mathbb{F}[X]$ have degree less than $k = 32{,}768$. Suppose an authenticated outer leaf at domain point a_i reveals $(p_0(a_i), \ldots, p_3(a_i))$. Any k leaves at distinct domain points uniquely determine all four polynomials.*

Proof. For each fixed row j, the leaves provide k evaluations $(a_i, p_j(a_i))$ at distinct points. A polynomial of degree below k is uniquely determined by those evaluations. Interpolate independently for $j = 0, 1, 2, 3$. □

For the source layout, concatenating the four recovered coefficient vectors recovers exactly $c \,\|\, r_{\mathrm{zk}}$. For the Definition 3.22 layout, the specified inverse split recovers the same two logical objects. Under the literal scalar-code reading, 32,768 disjoint stripes provide $N = 131{,}072$ scalar evaluations and determine the single degree-below-N encoding polynomial, provided the intended stripe-to-domain map is the disjoint packing described in the paper.

Theorem 1 (Equivalent signing-state recovery)**.** *For either four-row layout in Table 2, 32,768 distinct, authenticated initial leaves from one reused Jevil commitment determine an equivalent signing state. The state can produce fresh ordinary signatures without recovering the original 32-byte signing seed.*

Proof. Lemma 1 recovers every row. Re-encoding those rows reproduces the initial codeword and Merkle tree, hence the public root. Their coefficient allocation reconstructs c and r_{zk}, while the public relation $w = f(z)$ provides an independent binding check on c. These values determine the commitment state used by Open. The opening API takes fresh randomness ρ separately, so an attacker may sample unrelated new

proof coins and run the ordinary signing computation. Verification depends on the public root, message, claimed evaluations, and proof; it does not require the original seed. □

Theorem 1 concerns complete state recovery, not merely leakage. It survives the source's row-allocation error. Our executable demonstration uses the pinned source layout. The Definition 3.22 statement is an analytic design-level argument; we did not silently present the source execution as a separate paper-faithful implementation.

5 Attack algorithm

The adversary receives a public key pk and ordinary signing-oracle access under the advertised $n^\star = 1023$ budget.

1. Choose distinct messages $m_0, m_1, \ldots$ and request ordinary signatures. Never request query index 1,023, which would be signature number 1,024.
2. Run the unchanged ordinary verifier on every response. Replay its Fiat–Shamir transcript to derive the 64 first-round positions, verify each initial Merkle opening against the public root, and retain the four field elements at each position only after the complete proof has verified and the transcript has ended.
3. Deduplicate positions. Abort on conflicting values. Stop collection as soon as at least $k = 32{,}768$ distinct positions are available.
4. Select k positions. Fast-interpolate each of the four degree-below-k rows, then re-encode every row over the full 131,072-point domain. Require every retained opening, including those not selected for interpolation, to match the re-encoding.
5. Reconstruct the source's $c \,\|\, r_{\mathrm{zk}}$ layout. Require $w = f(z)$ and rebuild the commitment, requiring its Merkle root to equal the target public root byte for byte.
6. Build a signer cache from the recovered state, choose a message $m^\star$ absent from the oracle query set, and draw fresh proof randomness. Run the ordinary signing path on $m^\star$ and submit the result to the unmodified ordinary verifier.

The extractor in step 2 observes only data already sent to an ordinary verifier. The primary and independent recovery processes had no secret-key or original-cache input. Root reconstruction and $w = f(z)$ make coefficient order, field basis, domain indexing, and row assembly fail closed except under the underlying binding/collision assumptions.

Corollary 1 (Fresh-message forgery)**.** *If the algorithm reaches step 6, it produces an efficient fresh-message forgery and a reusable equivalent signing capability for the pinned profile.*

Proof. By Theorem 1, the reconstructed state opens the exact public commitment. The message is outside the signing-query set and the prover coins are freshly chosen. Completeness of the ordinary opening and verification paths therefore gives acceptance. The same recovered state can be reused with new messages and fresh coins. □

6 Sample complexity and success probability

In the Fiat–Shamir random-oracle model, distinct-message transcripts make the initial positions independent uniform draws with replacement from $N = 131{,}072$ outer leaves. After q signatures there are $d = 64q$ draws. If U_d is the number of distinct positions, then

$$\mathbb{E}[U_d] = N\left(1 - \left(1 - \frac{1}{N}\right)^d\right). \tag{1}$$

Solving $\mathbb{E}[U_d] = 32{,}768$ gives approximately 37,706.9 draws, or 589.17 signatures. This is an expectation, not a stopping guarantee. The attack counts actual positions and continues until the threshold is reached.

Changing one draw changes U_d by at most one. McDiarmid's bounded-difference inequality therefore gives, for $\mu_d = \mathbb{E}[U_d] > 32{,}768$,

$$\Pr[U_d < 32{,}768] \le \exp\left(-\frac{2(\mu_d - 32{,}768)^2}{d}\right). \tag{2}$$

Table 3 instantiates the expectation and this conservative bound. The observed counts closely match the occupancy expectation.

q	draws d	$\mathbb{E}[U_d]$	observed U_d	failure bound
641	41,024	35,224.60	35,203	$< 2^{-424}$
650	41,600	35,644.88	35,603	$< 2^{-574}$
1,023	65,472	51,534.14	—	$< 2^{-15,520}$

Table 3: Random-oracle occupancy estimates and measured distinct positions. The bounds are analytic and do not replace the attack's explicit threshold check.

Both retained attacks chose a comfortable fixed query count; neither searched for or claims the minimum successful count. Conditional on the random-oracle model, an incremental adversary that is allowed the full 1,023-query budget fails to collect enough positions with probability below the final row's bound.

Once k positions are available, standard product-tree interpolation costs quasilinear to $O(k \log^2 k)$ field operations per row, depending on the polynomial-arithmetic implementation. Four rows require $O(k)$ core state plus temporary interpolation storage. The recovered N-element witness occupies 4 MiB at 32 bytes per extension-field element; the full encoded slab occupies 16 MiB, and the initial binary Merkle tree uses about 8 MiB of digests. Oracle transcripts dominate storage: the independent 650-response corpus contained 219,867,416 serialized signature bytes. The measured peak resident memory remained below 151 MiB during public recovery.

7 Full-parameter experiments

7.1 Primary implementation

The primary experiment, `JEVIL-EXP-001`, used Rust 1.88.0 and the pinned upstream archive. The oracle generator wrote only a serialized public key, distinct query messages, ordinary signatures, range metadata, and hashes to the recovery boundary. The public recovery executable had no input path or API for the target secret seed or original signer cache. Every response passed ordinary verification before extraction.

The attack tree left the ordinary signer and verifier files byte-identical to the pinned source. Their SHA-256 digests were respectively

`34a61da541e7239402e2e49fedee76aaa50fc4c328c49cc9a307dca3bac2fb74`

and

`d84341b99aa3b76413c20118f7fb0a78886754e1d9c7c0f952c7f930037e569b`.

One preflight response and four disjoint 160-response shards covered indices 0 through 640. The public process received the five sealed public directories, verified 641 signatures, interpolated the state, and forged independently.

7.2 Hostile adversarial review

A separately tasked reviewer checked query accounting, freshness, public-only data flow, source identity, row semantics, root reconstruction, and the ordinary-verifier boundary. A checker linked only to pristine pinned source accepted the primary forgery and rejected changed-message, changed-root, and altered-signature controls. The reviewer then replayed all five sealed public input directories with no new signing query. It reproduced the 35,203 positions, row hashes, root, and controls, and generated a different accepted fresh signature. The review verdict was `PASS_WITH_LIMITATIONS / NO_TECHNICAL_VETO`.

7.3 Fresh-context independent reproduction

The `JEVIL-EXP-002` design was frozen before execution. A fresh-context agent began from a new extraction of the pinned source and the paper-level width-four observation. It separately wrote the observer, oracle, recovery, interpolator, state adapter, and clean-verifier driver. It did not import the

primary implementation, key, transcript, openings, recovered rows, or public artifacts. A new key seed was drawn from `/dev/urandom`; the recovery process could not read the private seed directory.

The independent interpolator used a subproduct tree, a complementary erasure locator derived from the product derivative, inverse radix-two transforms, and fast reversed power-series division. A synthetic four-row test passed before oracle collection. After recovery, the forgery was passed to a second source extraction whose upstream files were untouched; only an external verifier driver was added. Both the attack build and this untouched-source verifier accepted.

7.4 Results

Table 4 gives the two full-parameter trials. They used different keys, disjoint message namespaces, independently written attack code, and separate fresh proof randomness.

Run	queries	openings	distinct	fresh sig. bytes	verifier
Primary	641	41,024	35,203	343,532	accept
Independent	650	41,600	35,603	332,140	accept

Table 4: Full-parameter state recovery and fresh-message forgery.

The primary result recovered all four rows, reproduced the target root and $w = f(z)$, and signed an unqueried message. Its fresh signature SHA-256 was `3096cea57f85088a8a6c3eeba412b97a04a70ce940fd95696ff3b9f4b0f3f893`. The independent run reached the same endpoint on a new key; its fresh signature SHA-256 was `7e7b8fa3a213fcbfe6fe26792d5f8233df5268eb54914d217f3dd500e1066ed1`. Neither fresh signature appeared among its oracle responses.

The retained full-parameter empirical result is two successes in two trials, plus one public-data replay on the primary key. This does not justify a broad empirical rate estimate. Equation (2) supplies the conditional random-oracle success bound; every concrete run also checked the threshold directly before interpolation.

Stage	Wall time	Peak RSS	workers
Primary collection, each of four 160-query shards	198.48–203.05 s	131,060 KiB max	1 each
Primary public recovery, signing, and controls	486.90 s	143,756 KiB	1
Hostile public-data replay	475.63 s	143,920 KiB	1
Independent 650-response collection	13:19.13	131,256 KiB	1
Independent public recovery, signing, and controls	4:13.12	150,380 KiB	1
Independent untouched-source verifier and controls	0.93 s	91,840 KiB	1

Table 5: Measured full-parameter resources. The primary collection shards were independent processes; the other listed stages used one process and one logical CPU.

The experiments ran on x86-64 Linux with an AMD EPYC processor, 64 logical CPUs, and 131,880,760 KiB installed memory. Each experiment process stayed below a 4 GiB virtual-memory cap; no process approached the cap.

7.5 Negative controls

Both primary and independent runs enforced the following controls:

- every oracle response passed the ordinary verifier;
- the forged message was absent from the signing-query set;
- the forged signature differed from every oracle response;
- changing the message caused rejection;
- changing the public root caused rejection;
- altering the serialized signature caused rejection or parse failure;
- corrupting a recovered row failed root or public-evaluation binding; and
- signature 1,024 and zero-based query index 1,023 were never requested or consumed.

These controls rule out replay, a weakened attack verifier, wrong-root acceptance, coefficient recovery without a signing consequence, and accidental use of the advertised cliff.

8 Why this is below the advertised cliff

The advertised mechanism and this attack use different public information. Jevil's stated cliff counts the $K = 16$ message-derived evaluations $(x_t, f(x_t))$ in each signature and sets the polynomial dimension to $(n^\star + 1)K$. Its trigger is signature number 1,024.

Our attack ignores that recovery route. It accumulates the 64 initial width-four zk-WHIR leaves that ordinary proofs must reveal. The primary attack stopped at signature number 641; the independent reproduction stopped at 650. Their largest zero-based query indices were 640 and 649. Both are within the claimed operating budget and hundreds of signatures before the designed trigger.

The distinction also explains why recovering f alone would be insufficient. Ordinary signing needs the commitment state, including r_{zk}, to open the existing public root. The width-four route recovers that complete state. Fresh opening randomness then yields a reusable signer for the same public key.

9 Prior public records and attack-history limits

The final exact-target search covered the exact title and URL, ePrint and author indexes, citations, public repositories, issues, commits, advisories, crates, and combinations of Jevil with attack, cryptanalysis, forgery, width-four recovery, state recovery, and the measured query counts. It found no prior public practical signing attack against the frozen current profile within 1,023 ordinary queries. Two public records remain material and are disclosed here.

26 May root-binding forgery fix. Author-repository commit `3c7968ddacf4bddcbd178b3e7a61625148dabf9c` bound WHIR verification to `pk.root` and added a regression named `forged_root_attack_now_rejected` [5]. It documents a forgery against an earlier development state. The fix predates the paper's 29 May 2026 receipt and is present in the frozen target; the old forged-root proof does not verify under the current ordinary verifier. This public record precludes any claim that no Jevil development version had a forgery.

2 June non-power-of-two Merkle-helper report. A Swival trace published in the *security-audits* repository at commit `cea51fd3cec15036e4d845d0fb6d3f5628709d60` shows the multiproof verifier accepting padded index 13 for an artificial 13-leaf tree [6]. Its embedded `src/merkle.rs` is byte-identical to the frozen file. The audited Jevil profile constructs the relevant commitment sizes as powers of two, and ordinary verification derives positions modulo the codeword length instead of accepting an attacker-supplied padded index. The trace demonstrates no signing-state recovery, fresh-message forgery, or width-four accumulation attack against this profile. It is nevertheless a previously reported defect in the current source file and should not be omitted.

The history conclusion is therefore deliberately narrow: this is a practical below-budget attack on the current fourth-revision, source-backed profile. We make no unqualified priority statement.

10 Reproducibility and evidence identity

The primary and independent artifacts retain prospective designs, source manifests, locked dependency graphs, exact commands, machine descriptions, public query corpora, logs, results, and negative-control outputs. The critical sealed identities appear in Table 6.

To reproduce the endpoint, a run must pin the target above, generate a fresh $n^\star = 1023$ key, query no more than 1,023 distinct ordinary messages, and give its recovery process only the public key, messages, and serialized ordinary signatures. It must authenticate and verify openings before use, recover all four rows, match $w = f(z)$ and the exact root, sign an unqueried message with fresh randomness, and obtain acceptance from an ordinary verifier whose upstream acceptance logic is unchanged. A result that only recovers coefficients, substitutes an attack-specific verifier, or consumes signature 1,024 does not reproduce this claim.

Object	SHA-256
Primary result record	`36b01f7df957752489a163eabcce200c38e269f8a34f50b6045fe68c7591f3d4`
Primary 1,350-entry evidence manifest	`4f1b226bbdb82987bd3388d85e90e94362a5d5ceec397c7a2a062e2f1534f5b9`
Hostile-review handoff	`ad8af944d0b6b049f683c30158b43957a017b97d4bdcf72adbf3259920182b8b6`
Independent prospective design	`da0fd7bd14121b048ae8bdfbf338ac2afa930de60e14474f2a71e18e7f08dd8d`
Independent result record	`0d43f5ed095de93a12e16bfb96a2a6737654727b2488a9eb4431d5fe20793ce8`
Independent 1,453-entry manifest	`02414db4b8bd5d12d0065ae1fd452c46f07705b5380e769bb3b70018909a1e4c`

Table 6: Evidence seals for the reported results.

11 Limitations and design implications

The following limits are material to interpreting the result.

- The executable attack targets the frozen source commit and its $n^\star = 1023, c = 4$ row. The source predates the final PDF, revisions 1–3 were unavailable, and the final PDF does not pin a commit.
- The intended Definition 3.22 four-row result is analytic. The full attack was executed against the official source layout, whose contiguous split is nonconforming. The full-recovery threshold is the same, but earlier partial leakage differs. The paper's literal scalar stripe map is under-specified.
- The primary run and one independent fresh-key run are two successful full-parameter trials, not a many-key empirical study. The probability bounds assume the paper's Fiat–Shamir random-oracle model.
- Process isolation was enforced by separate executables, public-only argument and file boundaries, source audits, a scrubbed environment, and an unreadable independent seed directory. A mount-namespace sandbox and syscall trace were unavailable under the managed kernel policy.
- The primary key used a deterministic seed retained in the separate oracle-generator source, and the primary seal did not hash the exact primary-time release executable. Static data-flow and binary checks found no recovery path to that seed, the hostile reviewer replayed the sealed public inputs, and the independent run used a fresh random key whose seed was unavailable to its recovery process.
- Public attack-history search cannot exclude private, deleted, unpublished, or unindexed work, and several bibliographic endpoints were challenged or rate-limited.

The immediate design lesson is to account for one width-four leaf as four scalar disclosures, or as one disclosure in each of four separately masked rows. For the stated Definition 3.22 padding, the multi-opening hiding condition is $q\theta \le B/4$, which permits at most 448 signatures at $\theta = 64$, not 1,023. Merely lowering a counter avoids this demonstrated full-state threshold only by changing Jevil's advertised row. Preserving the 1,023-signature goal requires redesign: for example, enlarge the per-row dimension and masking budget consistently, avoid exposing reusable raw initial leaves, or refresh the commitment in a way that remains bound to the public key. Each option changes parameters or protocol structure and needs a new security analysis.

12 Conclusion

Jevil's ordinary proof reveals four initial Reed–Solomon values at each of 64 positions per signature. Because the commitment is reused and each of four rows has dimension 32,768, ordinary signatures accumulate enough authenticated positions to recover the entire committed state well before the intended 1,024th-signature cliff. The primary implementation did so with 641 signing queries; an independently written fresh-key implementation did so with 650. Both rebuilt the exact public state and produced fresh-message signatures accepted by untouched ordinary verification logic. The attack is standard interpolation applied to a width and budget mismatch, but its signing consequence is complete: it yields an equivalent signer inside the claimed 1,023-signature operating range.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

[1] N. Kobeissi, "Jevil: A Catastrophic-Failure-by-Design Signature Scheme," IACR Cryptology ePrint Archive, Report 2026/1103, revision 4, 2026. https://eprint.iacr.org/2026/1103

[2] A. Chiesa, G. Fenzi, and G. Weissenberg, "Zero-Knowledge IOPPs for Constrained Interleaved Codes," IACR Cryptology ePrint Archive, Report 2026/391, 2026. https://eprint.iacr.org/2026/391

[3] I. S. Reed and G. Solomon, "Polynomial Codes over Certain Finite Fields," *Journal of the Society for Industrial and Applied Mathematics*, vol. 8, no. 2, pp. 300–304, 1960.

[4] J. von zur Gathen and J. Gerhard, *Modern Computer Algebra*, 3rd ed., Cambridge University Press, 2013.

[5] N. Kobeissi, "Bind WHIR proof verification to the public-key root," `symbolicsoft/jevil` commit `3c7968ddacf4bddcbd178b3e7a61625148dabf9c`, 26 May 2026. https://github.com/symbolicsoft/jevil/commit/3c7968ddacf4bddcbd178b3e7a61625148dabf9c

[6] `jedisct1/security-audits`, "multiproof verifier accepts out-of-range indices," Swival trace in commit `cea51fd3cec15036e4d845d0fb6d3f5628709d60`, 2 June 2026. https://huggingface.co/datasets/jedisct1/security-audits/commit/cea51fd3cec15036e4d845d0fb6d3f5628709d60